

BEFORE Placeholder

AFTER

Resilience & Recovery Control Baseline (Tiered)

Document classification: Internal

Baseline owner: Security Engineering/Architecture (in coordination with Operations)

Version: 0.1

Effective date: _____

Review cadence: Annually (or after material outages)

1. Purpose

Define minimum resilience and recovery controls for third parties to support continuity of critical services, recovery from outages/incidents, and alignment to operational resilience expectations.

2. Scope

Applies to suppliers that:

- support business-critical services and/or regulatory reporting, and/or
- provide infrastructure/outsourced operations/MSP services, and/or
- host or process material volumes of organisational data, and/or
- provide services where loss of availability would materially impact clients or internal operations.

3. Control statements (tiered)

3.1 Tier Critical (Tier 1) — MUST controls

Critical suppliers MUST:

1. Provide a documented resilience approach appropriate to the service, including redundancy and recovery.
2. Define service restoration expectations and dependencies (including sub-processors and key infrastructure dependencies).
3. Maintain backup/restore capability where data is stored/processed and provide a high-level description of approach.
4. Perform periodic recovery/DR testing (service-appropriate) and provide a summary of last test (high level acceptable).
5. Support incident/outage communications:
 - named contacts
 - update cadence during major incidents/outages
6. Support continuity requirements for critical services:
 - document RTO/RPO capabilities where applicable, or equivalent restoration commitments.

Critical suppliers SHOULD:

- provide evidence of resilience monitoring/availability SLOs (where applicable)
- support multi-region resilience for high criticality services (where feasible)
- provide a post-incident RCA for material outages with corrective actions and dates

3.2 Tier Important (Tier 2) — MUST controls (proportionate)

Important suppliers MUST (where service stores/hosts data or is operationally important):

- provide basic availability and recovery approach (high level)
- provide backup/restore approach (if data hosted)
- provide incident/outage contact and communication approach

Important suppliers SHOULD:

- provide periodic restore testing confirmation (summary) where applicable.

3.3 Tier Low (Tier 3)

Low suppliers SHOULD:

- confirm whether the service stores any organisational data and how it is recovered if lost
- provide incident/outage contact details

4. Minimum requirements by control area

4.1 Criticality and service mapping

MUST:

- Identify whether the supplier supports a critical business service.
- Document:
 - impacted business process
 - workaround availability
 - maximum tolerable downtime (where known)

4.2 Availability design (resilience)

MUST (Critical):

- Describe:
 - redundancy model (single region, multi-zone, multi-region, active-active/active-passive)
 - key dependencies (identity provider, cloud provider, sub-processors)
 - maintenance windows and impact approach

SHOULD:

- Provide uptime/SLO targets where offered contractually.

4.3 Backup and restore

MUST (if supplier stores data):

- Describe:

- backup frequency
- restore method
- backup protection (immutability/segregation where applicable)
- restore time expectations (high level)

SHOULD:

- Test restores periodically and retain evidence (summary acceptable).

4.4 Disaster recovery / recovery testing

MUST (Critical, service-appropriate):

- Perform periodic recovery testing and provide:
 - last test date
 - test scope (what was tested)
 - outcome (pass/fail/partial)
 - corrective actions identified

SHOULD:

- Define DR test cadence (e.g., annual) appropriate to the service.

4.5 RTO/RPO and restoration commitments

MUST (Critical where meaningful):

- Provide RTO/RPO capabilities or equivalent restoration time commitments.
- Document any limitations or exclusions (e.g., certain regions, certain data classes).

SHOULD:

- Align commitments to the organisation's critical service requirements (where shared).

4.6 Outage communications and escalation

MUST (Critical/Important):

- Provide:
 - named incident/outage contacts (primary/secondary)
 - notification method and update cadence during major incidents
 - service status page/communication channel (if available)

SHOULD:

- Provide customer-facing post-incident RCA for material outages.

4.7 Concentration and single points of failure (Critical focus)

MUST (Critical):

- Identify any single points of failure (supplier itself, sub-processors, regions).
- Provide mitigation approach or rationale where mitigation is not feasible.

5. Validation steps (how to prove it)

For each supplier, record evidence location and complete checks.

5.1 Resilience documentation

☐ Resilience/availability approach provided (high level acceptable)

☐ Dependencies and limitations documented

Evidence location:

5.2 Backup/restore (if data stored)

☐ Backup frequency and restore approach confirmed

☐ Evidence of restore testing (summary acceptable) OR documented process

Evidence location:

5.3 DR/recovery testing (Critical)

☐ DR/recovery test summary reviewed (last test date, scope, outcome)

☐ Corrective actions (if any) captured and tracked

Evidence location:

5.4 RTO/RPO or restoration expectations

☐ RTO/RPO (or equivalent) provided and reviewed

☐ Alignment to criticality confirmed or gaps documented

Evidence location:

5.5 Communications

☐ Outage/incident comms contact details validated

☐ Update cadence expectations agreed

Evidence location:

6. Exceptions

If a Critical supplier cannot provide evidence of recovery testing or cannot meet restoration expectations:

- document the gap and business impact
- define compensating controls (e.g., workaround, manual fallback, scope restriction, additional monitoring)
- set an expiry date and remediation plan
- escalate for residual risk acceptance per governance

7. Sign-off (per supplier)

Supplier: _____ Service: _____ Tier: [] Critical []
Important [] Low

Security Engineering/Architecture (role title): _____ Date: _____ Operations / Service
Management (role title): _____ Date: _____ Business Service Owner (role title):
_____ Date: _____